agri-trust-agent 项目缺陷分析与优化方案

订单农业可信性 Agent · 华为 ICT 创新大赛参赛项目

生成日期：2026-10-12 | 依据：全量代码审查 + 测试实测结果

本报告基于对仓库后端全部核心模块（合同解析 / 标准校验 / 企业核验 / 履约模拟 / MCP 服务）与前端关键组件的逐文件审查，并在当前 Windows 开发机环境实际运行单元测试与端到端冒烟测试后得出。所有缺陷均标注证据与修复方案，按优先级排列。

一、验证结论

- 项目整体底子良好：排除 MCP 相关测试文件后，156 个单元测试全部通过；端到端冒烟测试 gate=OK、字段命中 8/8、条款切分 9 条、质量指标抽取出 3 项（水分≤14.5%、杂质≤1.0%、整精米率≥55%）。
- 存在 1 个 P0 阻断缺陷：MCP 依赖漂移导致 MCP Server 无法导入、全量 pytest 在收集阶段报错——直接堵死 AgentArts 接入（参赛资格线）。
- 存在 4 个 P1 级问题：标准校验判定结果前端不可见、AGENTS.md 与代码脱节、MCP simulate 工具参数丢失、缺少依赖 lock 文件。
- 另有若干 P2 级安全与正确性问题（doc_id 路径穿越风险、日期校验过宽、原件双写、/health 泄露路径等），以及 3 项 P3 级产品完善项。
- 文档状态：AGENTS.md 已与代码脱节——doc_id 冲突实际已在 2026-10-09 提交中修复（storage.py 采用微秒时间戳 + 随机后缀），但文档仍将其列为待办事项。

二、缺陷优先级矩阵

图中横轴为修复成本（低→高），纵轴为影响严重度（高→低），气泡大小代表严重度，颜色代表缺陷类别。位于左上区域（高影响、低成本）的缺陷应最优先处理。

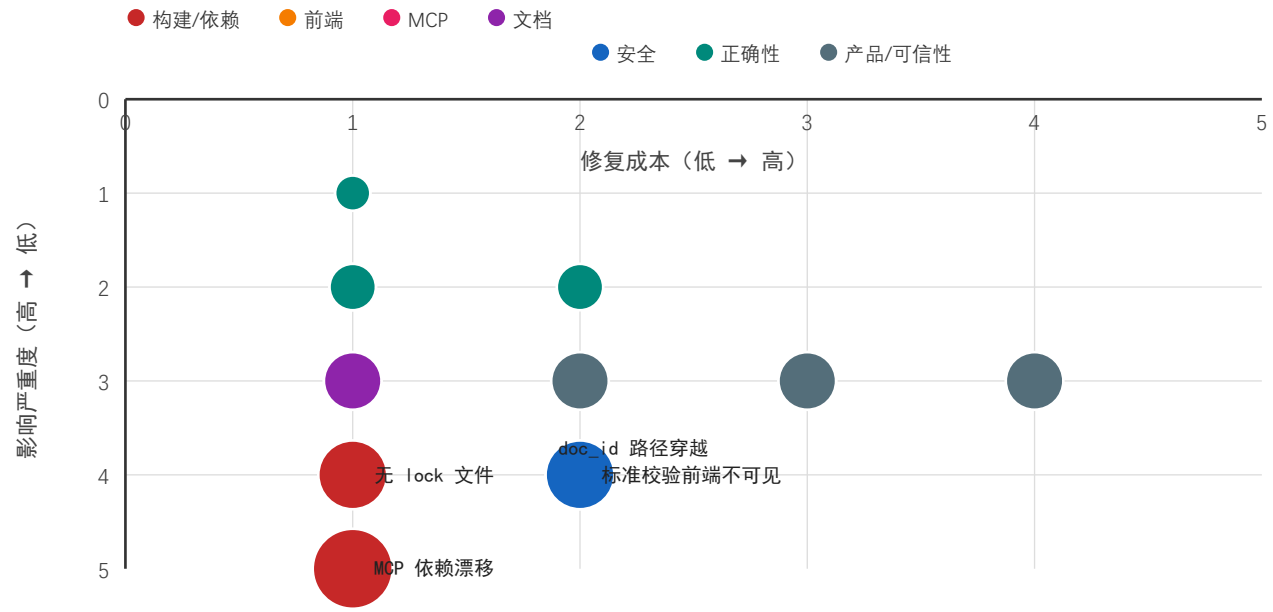


图 1：缺陷优先级矩阵（15 项缺陷 / 7 类）

三、缺陷清单与修复方案

级别	模块	问题	证据（已复现）	修复方案
P0	构建	mcp 2.x 依赖漂移，MCP Server 起不来	requirements.txt 写 mcp>=1.9.0，实际安装 2.3.0；mcp.server.fastmcp 在 2.x 已改名移除 → pytest 全量收集报错、import app.mcp.agri_server 失败	锁 mcp>=1.9.0,<2（10 分钟），或迁移到 2.x 的 MCPServer API；这是 AgentArts 参赛资格线的拦路虎
P0	构建	无 lock 文件（依赖漂移根因）	backend/requirements.lock.txt 不存在，AGENTS.md 要求提交但未提交	pip freeze > backend/requirements.lock.txt 并入库，跨机可复现
P1	前端	标准校验判定结果不展示	StandardPanel.vue 只渲染 coverage / matched_clauses，required_clauses、compliance 均 0 次引用	补齐必备条款缺失清单 + 数值合规比对的渲染（后端早已产出）
P1	文档	AGENTS.md 与代码脱节	new_doc_id() 已用微秒+随机后缀修复（10-09 提交），文档仍列待办；checklist.py 注释写 14 项，实际 11 必备 + 7 建议 = 18 项	同步文档：doc_id 已修复、清单口径统一为 18 项
P1	MCP	simulate 工具参数丢失	仅传 breach_party 时被「if scenarios is None and not filled: params={}」分支吞掉，违约方参数静默失效	改为 breach_party 独立追加，不依赖 if/elif 结构
P2	安全	doc_id 路径穿越风险	load_contract 直接拼接 f"{doc_id}.json"，读取前无白名单校验	读文件前用正则白名单校验 doc_id（^[0-9]{17,}-[0-9a-f]{4}$），禁止 ../ 序列
P2	安全	/health 泄露服务器路径	health 接口响应包含 base_dir 绝对路径	从响应中移除或脱敏服务器绝对路径
P2	安全	公网部署无认证 / 限流	parse / verify 等接口无认证、无限流；AgentArts 接入要求后端公网可达	部署前加 Token 认证与速率限制
P2	正确性	日期校验过宽	facts._to_iso 仅检查月 1-12、日 1-31，2026-02-31 这类不存在日期会被接受	改用 datetime.date 真校验，拒绝不存在的日期
P2	正确性	原件双写 + 孤儿文件	save_contract 同时写 contracts/{id}.pdf 与 uploads/{id}__*.pdf，中途崩溃会留下孤儿文件	改为单处存储，落盘原子化
P3	正确性	404 消息用错变量	simulation/router.py 第 43 行使用 payload.doc_id（缺省为空串）而非路径参数 doc_id	改用路径参数 doc_id 填充错误信息
P3	正确性	SQLite 死配置	config.py 声明 database_url=sqlite 但实际存储走 JSON 文件	删除死配置或真正启用数据库
P3	产品	LLM 抽取器从未实测	LLMStructurer 代码就绪但未接真实盘古跑过（AGENTS.md 已知项）	切 LLM_PROVIDER=pangu 后先冒烟验证再演示
P3	产品	判例库缺出处链接	cases_summary.json 50 条判例为知识提炼，无案号 / 裁判文书链接	补充案号与文书出处，答辩时证据链可追溯
P3	产品	汇总判定层 + 报告导出缺失	四模块结果割裂，无一键结论页（AGENTS.md 已知项）	串起四模块输出汇总结论页与报告导出

四、优化路线

阶段 ①：今天就能修（半天，必做）

- 锁定 mcp<2 并生成 requirements.lock.txt 入库 → 全量 pytest 恢复绿色 → MCP Server 可导入。
- 修复 MCP simulate 工具参数丢失 bug。
- 同步 AGENTS.md（doc_id 已修复、清单口径 18 项）。

阶段 ②：比赛前（1~2 天）

- 前端补齐标准校验判定展示（必备条款缺失 + 数值合规比对）——评委最可能现场点开的页面。
- doc_id 白名单校验 + /health 脱敏 + 日期真校验 + 404 变量修正。

阶段 ③：答辩加分（有余力）

- 接盘古实测 LLM 抽取器——AGENTS.md 下一步第 1 项，也是「华为技术」落地的关键证据。
- 判例库补充案号出处；汇总判定层串起四模块，输出结论页与报告导出。

五、验证方法与覆盖范围

本报告的结论均通过以下实测得到，可复现：

- 单元测试：python -m pytest backend/tests -q --ignore=backend/tests/test_mcp_compact.py → 156 passed（1.79s）。
- 全量测试：python -m pytest backend/tests -q → 因 mcp.server.fastmcp 缺失在收集阶段报错（mcp 2.3.0）。
- 端到端冒烟：python scripts/smoke_test.py → 解析门禁 OK、字段命中 8/8、条款 9 条、质量指标 3 项、结果落盘正常。
- MCP 导入验证：import app.mcp.agri_server → ModuleNotFoundError（mcp.server.fastmcp），确认阻断。

未验证项（如实披露）：api_test.py 需先启动服务、前端 npm build 未执行、真实盘古 LLM 链路未测。报告中「证据」一列均为本次审查中的代码事实或运行输出，可直接复核。